Security Incident Report

CLOUDORA | SECURITY OPERATIONS | SIMULATED SOC INVESTIGATION

Field	Details
Incident ID	CLD-0002
Title	Payroll-themed credential phishing campaign and account compromise
Analyst	Adam Shehayber
Incident date	August 25, 2026 (UTC)
Report date	October 19, 2026
Priority	P1 - two accounts compromised in the simulation
Status	Investigation completed; containment actions recommended, not executed
Environment	MyFirstHack / Cloudora synthetic training dataset

1. Executive summary

I investigated a payroll-themed phishing campaign in the simulated Cloudora environment. The emails pretended to come from HR and directed employees to a fake payroll portal. I used Azure Data Explorer and KQL to analyze message trace and sign-in records, determine who interacted with the links, and look for signs of stolen credentials being used.

The query results showed six phishing-link clicks and two credential submissions. I then correlated those users with successful sign-ins and found both accounts signing in from the same suspicious IP address, 198.18.7.200, associated with Amsterdam in the dataset. My findings support two compromised accounts: Freya Lynn and Ryan Boyd.

This is a simulated investigation. I documented the response actions I would recommend; I did not make changes to a production Microsoft 365 tenant.

2. Evidence and scope

Evidence reviewed: CloudoraMsgTrace_CL message trace events and CloudoraSignIn_CL authentication events, queried in Azure Data Explorer. My screenshots document campaign delivery/authentication, click events, victim sign-ins, and an attacker-IP pivot. The training materials also provide example email-header evidence, but the screenshots I submitted do not independently document my own full header-analysis or false-positive triage.

Investigation timeline

Times below reflect the synthetic August 25, 2026 event data. They are evidence points from my queries, not a record of actions I performed in a live tenant.

Time (UTC)	Source	Observation
08:47:12	Message trace	Freya Lynn clicked PayrollPhish-A and submitted credentials.
09:05:44	Message trace	Ryan Boyd clicked PayrollPhish-B and submitted credentials.
10:34:20	Sign-in logs	Freya account signed in from 198.18.7.200 (Amsterdam); Microsoft 365 activity followed.
13:22:05	Sign-in logs	Ryan account signed in from 198.18.7.200 (Amsterdam); subsequent Outlook Web App activity.

3. Investigation findings

Finding 1 - Two phishing variants were active. I grouped delivery events by campaign, sender IP, authentication outcome, and delivery action. PayrollPhish-A showed SPF, DKIM, and DMARC failures. PayrollPhish-B passed these checks, which does not make it trustworthy because the sender used a lookalike domain rather than the legitimate company domain.

Campaign / sender	Authentication	Delivery outcome
PayrollPhish-A / 198.18.44.10	SPF, DKIM, DMARC: fail	25 delivered; 7 quarantined
PayrollPhish-A / 198.18.44.23	SPF, DKIM, DMARC: fail	8 delivered
PayrollPhish-B / 198.18.51.7	SPF, DKIM, DMARC: pass	21 delivered

These are counts from the delivery-event grouping shown in my screenshot, not necessarily a count of unique people or unique messages across the full dataset.

Finding 2 - Six employees clicked. Filtering message trace data to EventType == "Click" returned six records. Two users had CredentialsSubmitted == "Yes"; four had "No". I prioritized the two credential-submitters for sign-in review.

Finding 3 - The credentials were subsequently used. I filtered successful sign-ins for the two credential-submitters. The data showed their normal UK sign-ins as well as activity from Amsterdam, with a different Windows 11 / Chrome device profile. The timing after the phishing clicks and the shared suspicious IP strongly supported account compromise.

Account compromise analysis

4. Confirmed affected accounts

Account	Evidence	Observed applications
Freya Lynn	Clicked and submitted credentials at 08:47 UTC. Successful sign-in from 198.18.7.200 at 10:34 UTC, following UK activity.	Microsoft 365, Outlook Web App, SharePoint Online
Ryan Boyd	Clicked and submitted credentials at 09:05 UTC. Successful sign-in from 198.18.7.200 at 13:22 UTC.	Microsoft 365, Outlook Web App

I used the suspicious IP prefix 198.18.7. to pivot across successful sign-ins. That query returned two accounts rather than one. This was important because stopping at the first victim would have missed the second account.

5. Indicators of compromise

Indicator	Why it matters
cloudora-hr-portal.example	Lookalike domain used in the phishing scenario
198.18.44.10	PayrollPhish-A sending infrastructure
198.18.44.23	Additional PayrollPhish-A sending infrastructure
198.18.51.7	PayrollPhish-B sending infrastructure
198.18.7.200	Shared IP for suspicious successful sign-ins to both affected accounts

All domains and IP addresses in this project are synthetic or reserved for training. They should not be represented as live, publicly verified malicious indicators.

6. MITRE ATT&CK mapping

Technique	ID	Evidence
Spearphishing Link	T1566.002	Phishing messages directed employees to credential-collection links.
Phishing for Information: Spearphishing Link	T1598.003	Users were prompted to enter credentials on the lookalike portal.
Valid Accounts: Cloud Accounts	T1078.004	Successful cloud sign-ins followed credential submission.

Response and recommendations

7. Recommended containment

The available lab lets me investigate and query synthetic logs, but it does not let me revoke sessions or block infrastructure in a live tenant. Based on the evidence, I would recommend the following response order:

Priority	Action	Reason
1	Revoke sessions and refresh tokens for both compromised accounts	Terminate potentially active attacker sessions immediately.
2	Reset both account passwords	Invalidate the stolen credentials.
3	Require or re-register MFA for the affected accounts	Reduce risk of password-only account takeover.
4	Block the phishing domain and identified sending/sign-in IPs	Prevent further access to known campaign infrastructure.
5	Purge remaining phishing emails from mailboxes	Reduce the chance of more employees clicking.
6	Re-run victim and attacker-IP queries after containment	Confirm that suspicious activity has stopped.

8. Detection and prevention improvements

I would recommend alerting on a successful sign-in from a new country within a few hours of a phishing-link click, particularly when the same user submitted credentials. I would also review mail controls for failed DMARC checks, watch for lookalike sender domains, require MFA, and communicate directly with employees who clicked without submitting credentials.

These are proposed improvements. My screenshots demonstrate investigative queries, not an implemented detection rule or completed containment verification.

Conclusion and supporting evidence

9. Lessons learned

This project showed me that identifying a suspicious email is only the first step. I needed to understand who received it, who clicked, whether anyone submitted credentials, and whether the attacker then used those credentials. KQL made it possible to connect the message trace and sign-in data and narrow the investigation to the accounts that needed attention most.

My biggest takeaway was to keep investigating after finding the first affected account. Pivoting on the suspicious IP uncovered a second compromised account, which changed the scope of the incident. I also learned why passing SPF, DKIM, and DMARC is not enough by itself to prove an email is safe: the domain being authenticated matters.

10. Evidence index

Artifact	Purpose
screenshots/01-delivery-authentication.png	Campaign variants, sender IPs, authentication and delivery outcomes
screenshots/02-phishing-link-clicks.png	Six click events and two credential submissions
screenshots/03-credential-victim-signins.png	Successful sign-ins for the two credential-submitters
screenshots/04-attacker-ip-pivot.png	Two accounts associated with 198.18.7.200
queries/investigation.kql	KQL queries used for the investigation

11. Portfolio disclosure

This is my report of a simulated SOC investigation using MyFirstHack Cloudora training data. The underlying scenario and sample incident-report structure were provided as training materials. The findings presented here are grounded in the KQL results I ran and documented. No production account changes, blocking actions, or real-world containment are claimed.

Analyst: Adam Shehayber